

User Stories – WBOCRM

Epic 1: Authentication & Access Control

US-01 – User Login

As a CRM user,

I want to log in with my email and password,

So that I can access the system securely according to my role.

Acceptance Criteria:

- Given valid credentials, a JWT token is returned and the user is redirected to the dashboard
- Given invalid credentials, a 401 error message is displayed
- Given no token on a protected route, the user is redirected to the login page
- Token expires after 30 minutes of inactivity

Role: All (admin, sales, support)

Priority: High

READ Reference: FR-AUTH-01, FR-AUTH-02

US-02 – Role-Based Access Control

As an administrator,

I want each user to only see pages and actions relevant to their role,

So that data is protected and the UI is not cluttered.

Acceptance Criteria:

- Sales users can access /leads but not /tickets or /users
- Support users can access /tickets and /leads/:id but not /leads or /users
- Admin users can access all pages
- Attempting an unauthorised route redirects to /dashboard
- API returns 403 when an insufficient-role token is used

Role: Admin

Priority: High

READ Reference: FR-AUTH-03, FR-AUTH-04

Epic 2: Lead Management

US-03 – Create New Lead

As a sales representative,

I want to register a new lead with contact details and engagement metrics,

So that the lead is tracked and scored in the pipeline.

Acceptance Criteria:

- Given a unique email, contact name, and metrics, a 201 response returns the new lead
- Priority score (0–100) is automatically calculated from the provided metrics
- Duplicate email returns a 400 DUPLICATE_EMAIL error
- Required fields (email, contact_name) validated before insertion

Role: Sales, Admin

Priority: High

READ Reference: FR-LM-01, FR-LM-02

US-04 – View and Prioritise Leads

As a sales representative,

I want to see all leads sorted by priority score,

So that I focus effort on the highest-value prospects first.

Acceptance Criteria:

- GET /api/leads returns leads ordered by priority_score DESC
- Each lead shows contact name, email, pipeline stage, score, and deal value
- List updates after creating, editing, or deleting a lead

Role: Sales, Admin

Priority: High

READ Reference: FR-LM-03, FR-SC-01

US-05 – Edit Lead Stage and Details

As a sales representative,

I want to update a lead's pipeline stage and deal value,

So that the pipeline reflects current deal status.

Acceptance Criteria:

- Valid stage values: New, Contacted, Qualified, Closed
- Invalid stage returns 400 INVALID_STAGE
- deal_value and campaign_id can be updated
- Lead not found returns 404

Role: Sales, Admin

Priority: Medium

READ Reference: FR-LM-04

US-06 – Delete a Lead

As a sales representative,

I want to delete a lead that is no longer relevant,

So that the pipeline stays clean.

Acceptance Criteria:

- Confirmation dialog shown before deletion
- Lead and all linked logs are deleted
- 200 response on success; 404 if lead not found

Role: Sales, Admin

Priority: Low

READ Reference: FR-LM-05

US-07 – Export Leads to CSV

As a sales manager,

I want to download the leads list as a CSV file,

So that I can analyse data in Excel or share it offline.

Acceptance Criteria:

- GET /api/leads/export/csv returns a .csv attachment
- CSV includes: lead_id, contact_name, email, pipeline_stage, priority_score, deal_value, campaign_id, created_at
- Download is triggered automatically in the browser

Role: Sales, Admin

Priority: Medium

READ Reference: FR-DOC-15

Epic 3: Lead Profile & Interaction Logging

US-08 – View Unified Lead Profile

As a CRM user,

I want to view a full profile page for each lead,

So that I have all relevant information — contact details, history, and tickets — in one place.

Acceptance Criteria:

- Profile page shows: contact name, email, stage, priority score, deal value, campaign ID, assigned user, created date
- Interaction log displayed in reverse chronological order
- Support users and admins see linked support tickets on the profile
- Back button returns to /leads

Role: Sales, Support, Admin

Priority: High

READ Reference: Section 3.8.3

US-09 – Add Interaction Note

As a sales representative,

I want to log an interaction note on a lead,

So that the communication history is preserved.

Acceptance Criteria:

- Note saved with timestamp via POST /api/leads/:id/logs
- Empty notes are rejected client-side
- Newly added note appears at the top of the timeline immediately

Role: Sales, Admin

Priority: Medium

READ Reference: FR-LM-06

US-10 – Assign Lead to Sales Rep

As an administrator,

I want to assign a lead to a specific sales representative,

So that ownership and accountability are clear.

Acceptance Criteria:

- Assignment dropdown shows only sales-role users
- PUT /api/leads/:id updates user_id
- Unassigned option available (null user_id)

Role: Admin

Priority: Medium

READ Reference: FR-SC-06

Epic 4: Support Ticket Management

US-11 – Create Support Ticket

As a support agent,

I want to create a support ticket linked to a lead,

So that customer issues are tracked and resolved systematically.

Acceptance Criteria:

- Ticket requires description, priority_level (Low/Medium/High/Critical), and lead_id
- 201 response with ticket_id on success
- Ticket appears in the lead's profile page

Role: Support, Admin

Priority: High

READ Reference: FR-ST-01

US-12 – Update Ticket Status

As a support agent,

I want to update a ticket's status as work progresses,

So that the team can see real-time progress.

Acceptance Criteria:

- Valid statuses: Open, In Progress, Resolved
- PUT /api/tickets/:id requires current updated_at for optimistic locking
- 409 CONFLICT returned if another user modified the ticket concurrently
- 200 response with updated ticket on success

Role: Support, Admin

Priority: High

READ Reference: FR-ST-02, NFR-ST-05

Epic 5: Dashboard & Reporting

US-13 – View Real-Time Dashboard

As a CRM user,

I want to see live KPIs on the dashboard,

So that I have an instant overview of the team's activity.

Acceptance Criteria:

- Dashboard shows: active lead count, open ticket count, top 5 leads by score, monthly revenue
- Data auto-refreshes every 2 seconds without page reload
- Monthly revenue = sum of deal_value for Closed leads in current calendar month

Role: All

Priority: High

READ Reference: FR-DA-01, NFR-ST-12

Epic 6: User Management

US-14 – Manage Users and Roles

As an administrator,

I want to view all users and change their roles,

So that I can onboard new team members and manage access.

Acceptance Criteria:

- GET /api/users returns all users (admin only)
- PUT /api/users/:id/role updates the role
- Valid roles: admin, sales, support
- Current user cannot change their own role
- System prevents demoting the last remaining admin (409 error)

Role: Admin

Priority: Medium

READ Reference: FR-UM-01, FR-UM-02

US-15 – GDPR/KVKK Lead Data Erasure

As an administrator,

I want to erase a lead's personal data upon request,

So that the organisation complies with GDPR/KVKK right-to-erasure obligations.

Acceptance Criteria:

- DELETE /api/leads/:id/personal-data anonymises email and contact name
- All interaction logs for the lead are permanently deleted
- Confirmation dialog shown before erasure
- Only admin role can perform this action (403 for others)
- Lead record remains with anonymised data ([Erased], erased_{id}@erased.invalid)

BDD Scenario:

```
Given I am authenticated as an admin user
And a lead with id 5 exists in the system
When I send DELETE to "/api/leads/5/personal-data"
Then the response status should be 200
And the lead email should be "erased_5@erased.invalid"
And the lead contact_name should be "[Erased]"
And the interaction logs for lead 5 should be empty
```

Role: Admin

Priority: High

READ Reference: NFR-ST-07

US-16 – KVKK User Data Erasure

As an administrator,

I want to erase a user's personal data,

So that the system complies with KVKK requirements.

Acceptance Criteria:

- DELETE /api/users/:id/personal-data anonymises user email and full name
- Admin cannot erase their own account data
- User record remains with anonymised fields
- Only admin role can perform this action

BDD Scenario:

Given I am authenticated as an admin user
And a user with id 3 exists
When I send DELETE to "/api/users/3/personal-data"
Then the response status should be 200
And the user full_name should be "[Erased]"
And the user email should be "erased_3@erased.invalid"

Role: Admin

Priority: High

READ Reference: NFR-ST-07

US-17 – PII Masking for Support Role

As a support agent viewing lead information,

I want personal data (email, name) to be masked,

So that data minimisation principles are enforced.

Acceptance Criteria:

- GET /api/leads returns masked email and name for support role users
- Email masked as a***@domain.com, name masked as A. L***
- Sales and admin roles see full unmasked data
- Dashboard top-5 leads also masked for support role

BDD Scenario:

Given I am authenticated as a support user
When I request the leads list
Then the response status should be 200
And lead emails should be masked (e.g. "a***@example.com")
And lead names should be masked (e.g. "A. L***")

Role: Support

Priority: High

READ Reference: NFR-ST-07

Epics 7: Data Lifecycle & Session Security

US-18 – Automatic Ticket Archiving

As an administrator,

I want resolved/closed tickets older than 365 days to be automatically archived,

So that the active ticket table stays performant and clean.

Acceptance Criteria:

- Daily cron job moves stale tickets (Resolved/Closed, updated_at > 365 days) to ArchivedTicket table
- Archive operation runs within a database transaction (INSERT then DELETE)
- Admin can manually trigger archiving via POST /api/tickets/archive
- Response includes the count of archived tickets

BDD Scenario:

Given I am authenticated as an admin user
When I send POST to "/api/tickets/archive"
Then the response status should be 200
And the response should contain "archivedCount"

Role: Admin

Priority: Medium

READ Reference: NFR-ST-15

US-19 – Idle Session Timeout

As a CRM user,

I want my session to automatically log out after 30 minutes of inactivity,

So that unattended sessions are secured.

Acceptance Criteria:

- 30-minute idle timer resets on user activity (mousemove, keydown, scroll, touchstart)
- Automatic logout clears JWT token from localStorage and redirects to login
- Timer is managed in AuthContext and applies to all authenticated pages

BDD Scenario:

Given I am authenticated and on any page
When 30 minutes pass without any user activity
Then the session token should be cleared
And I should be redirected to the login page

Role: All

Priority: Medium

READ Reference: NFR-SEC-04

US-20 – Offline Ticket Draft Caching

As a support agent,

I want my unsaved ticket draft to be preserved locally when the server is unreachable,

So that I do not lose my work.

Acceptance Criteria:

- Failed ticket creation stores form data in localStorage (crm_pending_ticket)
- On next page load, a banner shows with "Retry" and "Dismiss" options
- Successful retry clears the cached draft from localStorage
- Dismiss removes the cached draft without sending

BDD Scenario:

Given I have filled a ticket form with description "Network issue"
When the server is unreachable and I submit the form
Then the ticket data should be saved to localStorage
And when the server becomes available and I click Retry
Then the ticket should be created successfully
And the localStorage draft should be cleared

Role: Support, Admin

Priority: Low

READ Reference: NFR-ST-14